SHIELD-AI Deep Review: November 2026

Monthly Deep Review Report – Structural Gap Analysis and Framework Update (v1.19 to v1.20)

Security Architecture Practice

November 7, 2026

Abstract
The November 2026 monthly deep review of the SHIELD-AI framework: full Six Thinking Hats analysis of structural blind spots, six new incident clusters (INC-79..INC-84), two new structural gaps (G33 tool-connection and launch-path integrity; G34 cross-tenant isolation in pooled agent infrastructure) with two new controls (TP-16, MS-15), four control extensions (EE-01, MS-09, MS-13, MS-10), four field-finding adoptions, and a rebuilt watchlist. The review's central structural finding is the single-instance assumption: pooled multi-tenant agent memory, vector stores, and code-execution hosting are now a first-class isolation surface. Framework moved from v1.19 (67 controls) to v1.20 (69 controls).

SHIELD-AI Deep Review – November 2026

1. Scope and Method

This is the November 2026 monthly deep review of the SHIELD-AI framework (Mode A, full Six Thinking Hats sequence). Its purpose is structural blind-spot discovery: attack classes the framework systematically misses, rather than incremental mapping of stories onto existing controls. The review started from framework **v1.19** (7 pillars, 67 controls, 78 incidents INC-01..78, 32 gaps G1..G32) and ran the full hat sequence in the orchestrator (this cron run) using its own tool budget rather than

delegated subagents, keeping the research payload in the gap-analysis document (INC-79..INC-84).

Hat sequence: Blue (framing) -> White (research: web search across the Asia-Pacific and global agentic-security landscape since the October 12 release, window October 12 - November 7, 2026) -> Black (structural gap map) -> Green (control proposals) -> Red (gut-check) -> Blue (synthesis).

Evaluation criteria (Blue Hat framing): every candidate gap must carry a named incident; severity calibrated as new-class vs evidence-for-existing-control; proposals implementable as +/-1 controls or extensions; diagram representability; and the taxonomy's central assumption – "the agent as a single outbound actor with its own tools, identity, data, and sandbox" – inverted to locate the blind spots. The November review concentrated on the *single-instance assumption* the taxonomy has carried since v1.0: each agent (or each tenant) is modelled with its own memory and its own execution boundary.

2. Research Findings: New Incidents (INC-79..INC-84)

INC	Incident	Date(s)	Source	Class
INC-79	opencode MCP OAuth RCE: remote MCP server authorization_endpoint reaches a browser-launch/ PowerShell primitive at sign-in; no origin comparison; no CVE/advisory	reported Aug 29, patched Sept 28, disclosed Oct 19 2026	Pillar Security	Tool-connection / launch-path execution
INC-80	MCP tool-argument command-injection wave: eight VulnCheck CVEs (CVE-2026-117558..117569) + functype-mcp-server CVE-2026-59176 (package-spec to code exec) + Langflow CVE-2026-105740 (actively exploited, 1,423 honeypot attempts)	Oct 27-28 2026; Langflow active Sep-Oct 2026	NVD/ VulnCheck, The Production Agent, The Hacker News	Tool-argument injection (recurring INC-76)
INC-81	Cross-tenant agent memory leakage: MemLeak shared-vector-		arXiv 2610.04195;	Cross-tenant memory /

INC	Incident	Date(s)	Source	Class
	store semantic leakage (incidental 70-100%, adversarial 90-100%); Strands Agents Tools memory-namespace IDOR (GHSA-mpxq-953j-42m4, CWE-639); Ryvane cross-tenant write (CVE-2026-2018/2104)	October 2026	Strands advisory	pooled-store isolation
INC-82	Multi-tenant AI code-execution hosting tier escapes: Beta9/Beam (CVE-2026-120306/120307/120308, CVSS 9.9 x3); Prefab UI (CVE-2026-120338, CVSS 10.0); ServiceNow Rhino (CVE-2026-103093); OpenHands (CVE-2026-112346); Flowise vm2	Nov 1 2026 (JFrog); Oct-Nov 2026	JFrog Research, NVD, VulnCheck	Multi-tenant execution hosting isolation
INC-83	CI/CD agent config-file trust-ordering and marker authorship: GitInject config-file-precedence flaw (attacker branch config loaded as operator instruction); Radware 145M-item GitHub hidden-text census (friendly notes grow 5x, spoofable)	Oct-Nov 2026	GitHub Inject (Virginia Tech), Radware	Instruction-source trust-ordering / authorship
INC-84	Visual prompt injection into agent ability configuration: Repeat-After-Me black-box adaptive visual PI; OpenClaw TOOLS.md overwrite from a minimally injected image	Sep 15 2026 (arXiv); Nov 2026	AISec '26 (UC Berkeley/ FAIR at Meta)	Multi-modal instruction channel into self-configuration

Coverage-window note. All six clusters are new since the October 12 release (or published in the same window but not previously logged). None was already covered by a named gap; the two most distinctive become G33 and G34.

3. Black Hat: Structural Gap Map

#	Candidate gap class	Severity	Evidence	Verdict
1	MCP/tool connection-path execution: remote peer-supplied protocol metadata (OAuth discovery, authorization_endpoint, server definitions) reaching a process-launch primitive at connect time, despite URL-scheme checks	Critical	INC-79 (opencode), INC-80+180 (Copilot CVE-2026-103572), CVE-2025-6514	New gap G33
2	Cross-tenant isolation in pooled agent infrastructure: shared vector/memory stores leak or are steered across tenants via cosine similarity or LLM-controllable keys; multi-tenant execution hosting lets a tenant reach the worker root	High	INC-81 (MemLeak, Strands, Ryvane), INC-82 (Beta9/ Beam)	New gap G34
3	MCP tool-argument command injection recurring at scale (nine servers, one bug)	High	INC-80	Accelerates G27/TP-15, INC-76; no new gap
4	Instruction-source trust-ordering / marker authorship	High	INC-83 (GitInject, Radware)	Escalates G28/MS-13 extension
5	Multi-modal instruction channel into agent self-configuration	Medium	INC-84 (Repeat-After-Me)	Escalates G15/MS-09 extension

The Black Hat's central observation: the White Hat's incident x control table showed most electronic new incidents covered (sandbox escapes map to G1, auth-off-by-default to MS-08, loopback to EE-07) – expected for a mature taxonomy. The genuinely uncovered classes both trace to the **single-instance assumption**: the inference that one agent (or one tenant) owns its memory and compute. Two strong 2026 evidence streams – the cross-tenant memory/vector-store results and the multi-tenant hosting-tier escapes – show the assumption is structural, not incidental:

modern deployments pool memory and compute across tenants by design, and neither the pooling boundary (G34) nor the connection adapter that reaches a remote server (G33) is a boundary the taxonomy models.

4. Green Hat: Control Proposals

Proposal	Decision	Control	Fail-closed note
Tool-connection and launch-path integrity	New control (G33)	TP-16	Any transport field crossing into a launch/shell primitive terminates the connection and alerts; no origin-bound endpoint, no sign-in
Cross-tenant agent memory and state isolation	New control (G34)	MS-15	Memory tool refuses an unverifiable or out-of-scope ownership claim rather than serving/writing
Multi-tenant execution hosting tier	Extension	EE-01	Container-root-escaping path resolution rejected; chroot-only isolation fails closed to OCI isolation
Multi-modal instruction channels into self-configuration	Extension	MS-09	Agent's own ability/config surface never writable from model-visible content
Instruction-source trust-ordering and authorship	Extension	MS-13	Untrusted branch config never loads as operator instruction before content processing

5. Red Hat: Gut Check

- **Security engineer:** TP-16 is the control that connects the MCP OAuth RCE and the .mcp.json launch-registration bugs – adapter-level origin-binding is what they will actually build, and "no transport-to-execution cross" gives them a testable invariant rather than a softer best practice. They may push back that MS-15's hard ownership gating degrades pooled collaborative memory; the counter is that

collaboration must be an *explicit, authorised* pool, not an implicit similarity-measured one.

- **CISO:** the cross-tenant leakage finding (MemLeak) is a board slide – “your pooled agent memory leaks across users at 70-100% without any attacker” is immediately actionable and drives MS-15 funding. They will want the multi-tenant hosting-tier escapes (Beta9/Beam) framed as a supply-chain/vendor-assurance question (GRM-04), not just an EE-01 engineering fix.
- **Platform operator:** the biggest operational friction is MS-15’s post-retrieval ownership gating on shared project spaces. The risk of it being disabled under collaboration pressure is real; the mitigations are default-deny with an explicitly-admit-to-pool workflow and monitoring that treats an unadmitted cross-tenant hit as a control violation.
- **Executive:** MCP connection-path RCE and cross-tenant memory leakage are both customer-data and integrity risks an auditor will probe. Both are cheap to describe in a risk register and map cleanly to existing incidents, so adoption is likely.

6. Blue Hat: Synthesis

Verdict: structural gaps confirmed – apply now. Two new controls (TP-16, MS-15), four control extensions (EE-01, MS-09, MS-13, MS-10), six new incident clusters, and two new gaps (G33, G34) are adopted into the framework at v1.20 (69 controls). The single-instance assumption is named as a structural-review lesson for future cycles: any pooled, shared, or shared-index surface (memory, vector store, execution worker, connection adapter) is a candidate isolation boundary until proven otherwise.

The watchlist is rebuilt with the cross-tenant pooled-infrastructure theme promoted to a control (MS-15) and the tool-connection theme promoted to a control (TP-16), and two watchlist components are updated to reflect the new evidence.

Framework result: v1.20 – 7 pillars, 69 controls (MS 15 / IAM 10 / DS 8 / TP 16 / MIR 6 / GRM 6 / EE 8), 84 incidents, 34 gaps.